

ORION HEALTH SERVICES

Cybersecurity Incident Report

Incident Reference	INC-2024-0317
Incident Type	Ransomware Attack
Date Detected	Monday, 17 March 2025
Severity	CRITICAL
Status	Under Investigation — Containment Phase
Prepared By	Roni Biju
Audience	Executive Leadership Team — CONFIDENTIAL

CONFIDENTIAL — FOR INTERNAL DISTRIBUTION ONLY

1. Executive Summary

On the morning of Monday, 17 March 2025, Orion Health Services detected a ransomware attack affecting critical internal infrastructure. The attack began via a phishing email delivered to a member of the finance team containing a malicious Excel attachment. Once executed, the malware propagated across the network, encrypting files on the file server, HR and finance systems, and partially compromising the backup server.

By midday, multiple employees had been locked out of core systems. A ransom note was discovered on the shared drive. The threat actor leveraged credential harvesting tools (Mimikatz) and used overseas infrastructure to maintain access prior to deployment of the ransomware payload.

Sensitive data — including employee payroll records, patient appointment schedules, and internal system credentials — is believed to have been accessed and may have been exfiltrated prior to encryption. Encrypted files carry the extension .orionlock.

● Systems Affected	⚠ Data Compromised	🕵 Attack Vector	📋 Severity
3 systems (1 partially)	3 data categories	Phishing email (Excel attachment)	CRITICAL

2. Incident Timeline

The following timeline reconstructs the sequence of events based on system logs, employee reports, and initial forensic analysis.

Date	Time (AEST)	Event
Mon 17 Mar	~Fri–Sun	Threat actor sends phishing email to finance team member containing a malicious Excel attachment. Email bypasses spam filters.
Mon 17 Mar	08:00–08:30	Finance team member opens the malicious Excel attachment, enabling macros. Initial malware payload executes on the endpoint.
Mon 17 Mar	08:30–09:30	Malware uses Mimikatz to harvest credentials from memory. Attacker establishes lateral movement across the internal network using stolen credentials.
Mon 17 Mar	~09:00	Suspicious login from an overseas IP address detected (later identified in log review). Attacker gains access to core servers.
Mon 17 Mar	09:30–11:00	Ransomware payload deployed. File server, HR and finance systems begin encrypting files. Files receive .orionlock extension.
Mon 17 Mar	~10:00	Backup server begins partial encryption. Some backups preserved due to segmentation.
Mon 17 Mar	11:00–12:00	Multiple employees report inability to access systems and files. IT Help Desk escalates.
Mon 17 Mar	~12:00	Ransom note discovered on shared drive. IT team identifies unusual outbound traffic. Security team engaged.

Mon 17 Mar	12:00 onward	Incident response initiated. Containment procedures begin. This report prepared for executive briefing.
------------	--------------	---

3. Attack Analysis

3.1 Initial Entry Point

The attack originated from a spear-phishing email delivered to a finance team employee. The email contained a malicious Microsoft Excel attachment which, upon opening, prompted the user to enable macros. Once enabled, the embedded macro executed a dropper that downloaded and installed the ransomware components onto the host machine.

This technique — known as a macro-enabled document attack — remains one of the most prevalent and effective initial access vectors. Finance team members are frequently targeted due to their access privileges across financial and HR systems.

3.2 Credential Harvesting — Mimikatz

Following initial execution, the attacker deployed Mimikatz, an open-source credential extraction tool widely used in post-exploitation scenarios. Mimikatz was used to extract plaintext credentials, NTLM hashes, and Kerberos tickets from Windows memory (LSASS process).

With harvested credentials, the threat actor was able to authenticate to additional internal systems without triggering standard password-based alerts, enabling rapid lateral movement across the network.

3.3 Lateral Movement & Privilege Escalation

Using the harvested credentials, the attacker moved laterally to compromise the file server, HR and finance systems, and the backup server. The use of legitimate credentials makes this phase particularly difficult to detect without behavioural monitoring tools (e.g., UEBA).

Critically, the attacker gained access to the backup server — a common ransomware tactic designed to eliminate the organisation's primary recovery option. Partial encryption of backups suggests some degree of network segmentation was effective in limiting full compromise.

3.4 Ransomware Deployment

The ransomware payload encrypted files across affected systems, appending the .orionlock extension to all encrypted files. A ransom note was deposited on the shared drive containing payment instructions. The specific ransomware variant is yet to be identified pending deeper forensic analysis.

Prior to encryption, it is likely — and should be assumed — that the attacker exfiltrated sensitive data. This is consistent with modern "double extortion" ransomware tactics, where attackers threaten both to release stolen data and to maintain encryption unless a ransom is paid.

4. Indicators of Compromise (IOCs)

The following IOCs have been identified during initial investigation. All IOCs should be fed into the SIEM, firewall blocklists, and endpoint detection tools immediately.

IOC Type	Indicator	Description / Significance
Network	Overseas IP Address (TBC — log review in progress)	Suspicious authenticated login from a foreign IP. Likely used for C2 communication and initial network access after credential harvesting.
Tool / Binary	Mimikatz (mimikatz.exe or in-memory variant)	Credential dumping tool used to extract NTLM hashes and Kerberos tickets from LSASS. Presence confirms post-exploitation lateral movement.
File Extension	.orionlock	Custom extension appended to all files encrypted by the ransomware payload. Unique to this attack campaign or group.
Behaviour	Unusual outbound network traffic	Detected by IT team Monday morning. Likely data exfiltration prior to ransomware deployment, consistent with double extortion TTPs.
File / Artefact	Ransom note on shared drive	Ransom demand deposited to shared drive accessible by multiple employees. Exact content and demands to be documented and preserved as evidence.

5. Compromised Data Assessment

The following categories of data are believed to have been accessed and/or encrypted during the attack. Given indicators of pre-encryption exfiltration activity, all categories should be treated as potentially exfiltrated until forensic analysis confirms otherwise.

Data Category	Data Subjects	Sensitivity	Regulatory Obligations
Employee Payroll Records	~250 staff	HIGH	Privacy Act 1988 (AU); NZ Privacy Act 2020. Notifiable Data Breach (NDB) assessment required.
Patient Appointment Schedules	Multiple clinic patients	CRITICAL	My Health Records Act (AU); Health Information Privacy Code (NZ). Mandatory breach notification likely required.
Internal System Credentials	IT / All staff	HIGH	Immediate forced reset required. Risk of further unauthorised access to interconnected clinic systems.

⚠ Regulatory Alert: Patient data exposure likely constitutes a notifiable data breach under the Australian Privacy Act 1988 and potentially under the NZ Privacy Act 2020. The Office of the Australian Information Commissioner (OAIC) and relevant NZ authorities must be notified within 30 days of becoming aware of the breach. Failure to notify may attract significant penalties.

6. Affected Systems

System	Status	Impact
--------	--------	--------

File Server	FULLY ENCRYPTED	All files encrypted with .orionlock extension. Primary data repository unavailable. Full forensic preservation required before any recovery attempts.
HR & Finance Systems	FULLY ENCRYPTED	Payroll and HR records inaccessible. Finance operations halted. Employees locked out. Contains most sensitive internal data.
Backup Server	PARTIALLY ENCRYPTED	Some backups preserved. Extent of compromise under investigation. Integrity of remaining backups must be verified before using for restoration.

7. Immediate Response Actions Taken

The following containment and initial response steps have been or are being undertaken:

- Isolated affected systems from the network to prevent further lateral movement and encryption spread.
- Blocked identified suspicious IP addresses at the perimeter firewall.
- Initiated forced password reset for all active user accounts, prioritising privileged and administrative accounts.
- Engaged forensic preservation on affected servers — no recovery actions to be taken until forensic images are secured.
- Notified executive leadership team and initiated incident response protocol.
- Preserved the ransom note as evidence; no response to the attacker has been made.
- Commenced review of authentication logs to identify the full scope of the overseas IP access.
- Verified integrity of uncompromised backup segments before using for recovery planning.

i Note on Ransom Payment: Paying a ransom does not guarantee decryption of files or prevent the release of stolen data. Payment may also expose Orion Health Services to legal risk. The decision to pay must only be made after consultation with legal counsel, law enforcement (Australian Federal Police / CERT Australia), and senior leadership.

8. Recommendations

8.1 Immediate Actions (0–72 Hours)

- **Priority:** Engage an external incident response (IR) firm to conduct a full forensic investigation.
- **Priority:** Notify the OAIC and relevant NZ Privacy Commissioner of the potential notifiable data breach.
- **Priority:** Brief clinic partners in Australia and New Zealand on potential data exposure and precautionary measures.
- **Priority:** Perform complete credential reset across all systems including service accounts and API keys.
- **Priority:** Determine ransomware variant to assess whether decryption tools exist (e.g., via No More Ransom project).

8.2 Short-Term Actions (1–4 Weeks)

- Rebuild affected systems from clean images rather than decrypting in place where possible.

- Implement network segmentation review to prevent future lateral movement.
- Deploy or review endpoint detection and response (EDR) tooling across all endpoints.
- Enable multi-factor authentication (MFA) on all internal systems and remote access solutions.
- Conduct mandatory security awareness training for all staff, with focus on phishing identification.
- Review and restrict macro execution policies in Microsoft Office across the organisation.

8.3 Long-Term Actions (1–3 Months)

- Implement a SIEM solution with 24/7 alerting to detect anomalous behaviour and credential misuse.
- Adopt a Privileged Access Management (PAM) solution to control and audit administrator credentials.
- Establish an offline, air-gapped backup solution following the 3-2-1 backup rule.
- Conduct a full third-party penetration test once systems are restored and hardened.
- Develop and test a formal Incident Response Plan (IRP) and Business Continuity Plan (BCP).
- Review contractual and insurance obligations related to cyber incidents and data breaches.

9. Regulatory & Legal Obligations

Given the nature of the compromised data, Orion Health Services faces obligations under several regulatory frameworks. Legal counsel should be engaged immediately.

Regulation / Framework	Jurisdiction	Obligation
Privacy Act 1988 — Notifiable Data Breaches (NDB) Scheme	Australia	Notify OAIC and affected individuals if breach likely to result in serious harm. Notification required as soon as practicable.
My Health Records Act 2012	Australia	Additional obligations for systems handling My Health Record data. ADHA notification may be required.
Privacy Act 2020	New Zealand	Notify Office of the Privacy Commissioner (NZ) of notifiable privacy breach. 72-hour timeframe for serious harm notifications.
Health Information Privacy Code 2020	New Zealand	Specific obligations for health information. Applies to patient appointment data held on behalf of NZ clinics.
Australian Signals Directorate (ASD) / ACSC	Australia	Report cybersecurity incidents to the Australian Cyber Security Centre (ACSC). Voluntary but strongly recommended.

10. Next Steps & Escalation

The following actions require executive decision or resource authorisation:

#	Action Item	Owner	Deadline
1	Engage external IR/forensics firm for full investigation	CTO / CEO	Immediate
2	Notify OAIC (AU) and Privacy Commissioner (NZ) of data breach	Legal / DPO	Within 72 hrs

3	Inform affected clinic partners of potential patient data exposure	CEO / Comms	Within 24 hrs
4	Obtain legal advice on ransom payment decision	CEO / Legal	Immediate
5	Notify cyber insurance provider and initiate claim process	CFO / Legal	Within 24 hrs
6	Approve budget for IR firm, system rebuild, and security uplift	CFO / Board	Within 48 hrs
7	Prepare internal staff communication regarding system outages	HR / Comms	Within 24 hrs
8	Commission post-incident penetration test (post-recovery)	CTO	1–3 months

This report was prepared by the Internal Security Team for executive review.

Orion Health Services — CONFIDENTIAL — INC-2024-0317